

Mémo Oral BTS SIO – Veille Technologique

Zero Trust Security · Antoine Pageot · Fénelon Sup Paris

1. Ce que tu dis pour présenter le sujet

"Ma veille porte sur le **Zero Trust Security**. C'est un modèle de cybersécurité dont le principe est : **ne jamais faire confiance, toujours vérifier**. Contrairement aux réseaux traditionnels où tout ce qui est à l'intérieur est considéré comme sûr, le Zero Trust part du principe qu'aucun utilisateur, aucune machine, ne doit être automatiquement de confiance — même en interne."

"J'ai choisi ce sujet car il est directement lié à mon option SISR : Active Directory, identités, VLANs, GPO — tout ce que j'ai travaillé en cours et chez IPACS."

2. Ta méthodologie de veille

"J'utilise **Feedly** pour centraliser les flux RSS de l'ANSSI, du NIST et de The Hacker News, et **Google Alertes** sur mes mots-clés : Zero Trust, NIST 800-207, CVE Active Directory. Je consulte tout ça environ deux fois par semaine et je fais une fiche de synthèse environ une fois par mois."

3. Tes 3 fiches de veille

#01 NIST SP 800-207 — Formalisation du modèle Zero Trust Architecture

MOYEN

Date : 14/10/2024

Source : NIST – nist.gov

Résumé

Référence officielle du Zero Trust. Définit 7 principes : vérification des identités, moindre privilège, micro-segmentation, refus implicite par défaut, authentification continue.

Impact

Toutes les entreprises avec un réseau traditionnel basé sur le périmètre réseau. Redéfinit la gestion des accès AD et GPO.

Action

Revoir la segmentation AD (OU, groupes, droits NTFS), renforcer le MFA, documenter tous les flux.

Formation

Appliqué dans ma mission E5 : GG_Support n'accède qu'au dossier Support — principe du moindre privilège.

Zero Trust	NIST 800-207	micro-segmentation	IAM	moindre privilège	MFA
------------	--------------	--------------------	-----	-------------------	-----

#02 Microsoft Entra ID — Azure AD évolue vers une plateforme Zero Trust

ÉLEVÉ

Date : 06/03/2025

Source : Microsoft Learn

Résumé

Microsoft a renommé Azure AD en Entra ID. Intègre MFA natif, Conditional Access, PIM (droits admin temporaires), SSO cloud et on-premise.

Impact	Entreprises avec AD on-premise souhaitant évoluer vers le cloud hybride. Les comptes admins sont ciblés par PIM.					
Action	Activer MFA pour tous les admins. Mettre en place l'accès conditionnel. Utiliser PIM pour que les élévations soient tracées.					
Formation	Mon AD ipacs.local peut évoluer vers Entra ID. Ma mission E5 préfigure cette intégration cloud.					
Entra ID	Azure AD	MFA	Conditional Access	PIM	SSO	AD hybride

#03 CVE-2024-49113 — Faille critique LDAP Windows Server (CVSS 9.8)					CRITIQUE
Date : 18/11/2025		Source : MSRC Microsoft + CERT-FR			
Résumé	RCE dans le service LDAP de Windows Server. Attaquant non authentifié peut exécuter du code sur un contrôleur de domaine via paquet LDAP malformé. Score CVSS 9.8.				
Impact	Tous les contrôleurs de domaine exposant le port 389 sans filtrage. Compromission totale de l'AD possible.				
Action	Appliquer correctif KB5048667. Restreindre port 389 par pare-feu. Activer journalisation LDAP.				
Formation	Concerne mon Windows Server 2025 chez IPACS. J'ai configuré l'Observateur d'événements pour surveiller ipacs.local.				
CVE-2024-49113	LDAP	Active Directory	RCE	CVSS 9.8	Patch Tuesday

4. Questions fréquentes du jury

■ C'est quoi concrètement le Zero Trust ?

"C'est un modèle où on ne fait confiance à personne par défaut. Chaque connexion est vérifiée, chaque accès limité au strict nécessaire. Dans mon AD, chaque service a ses propres droits NTFS et ne peut pas accéder aux dossiers des autres."

■ Quel est le lien avec ta mission E5 ?

"Dans ma mission AD j'ai appliqué le moindre privilège : GG_Support n'a accès qu'au dossier Support, pas aux autres. C'est exactement ce que préconise le NIST 800-207."

■ C'est quoi une CVE ?

"Une CVE c'est une vulnérabilité référencée publiquement avec un identifiant unique et un score CVSS de 0 à 10. La CVE-2024-49113 est à 9.8 — critique — elle permet d'exécuter du code à distance sur un contrôleur de domaine sans s'authentifier."

■ Tu fais ta veille à quelle fréquence ?

"Je consulte Feedly et Google Alertes environ deux fois par semaine. Je fais une fiche de synthèse environ une fois par mois sur les sujets importants."

■ C'est quoi le NIST ?

"C'est le National Institute of Standards and Technology, un organisme américain qui publie des standards de cybersécurité. La SP 800-207 est leur référence sur le Zero Trust, utilisée par les entreprises du monde entier."

■ Pourquoi ce sujet ?

*"Parce que le Zero Trust est directement lié à mon quotidien SISR : AD, GPO, droits NTFS, VLANs.
C'est aussi le modèle adopté par Microsoft, Cisco et Google aujourd'hui."*

Bon courage Antoine ! ■